

DAIH Workspace Platform

Cross-Stack Quality Assurance Report

Executive decision: NO-GO for production release

The combined frontend and cross-stack source reviews identify release-blocking risks in payment accuracy, identity and access, QR pass trust, and loyalty-data migration. The notes report static code traces only; the application, payment flows, database migrations, and browser journeys were not executed.

26	11	13	2
distinct findings	P1 release blockers	P2 operational risks	P3 follow-ups

Release gate

Do not release for real customer payments, access passes, or sensitive admin use until every P1 item is corrected and verified in an isolated environment. Do not apply the loyalty table-drop migration until data preservation is proven.

Scope: Public web, customer PWA, reception terminal, admin portal, shared API client/types, API services, Prisma schema and migrations, worker paths, CI, and deployment guidance.

Snapshot: The cross-stack note reports commit ced762d. The frontend-only note does not identify its commit, so matching snapshots were not independently verified.

Prepared: 28 September 2026

1 Executive decision

The release should remain on hold. The P1 set includes several independent failure modes across money movement, customer identity, access passes, authorization, and data preservation. Fixing one theme does not close the others.

- Payment correctness: the API does not receive the booking quantity, settlement does not reconcile amount and currency, retry paths can create multiple pending attempts, and refund approval can call the provider before a local atomic claim.
- Security and access: legal HTML is rendered unsanitized, credentialed CORS trusts a broad subdomain pattern, OAuth exposes an access token in the URL, and QR authenticity/role checks are too broad.
- Data and permissions: the loyalty migration drops legacy tables without a backfill, and Operations payment access exceeds the shared permission model.
- Operational reliability: webhook acknowledgement, check-in concurrency, outbox claiming, retention, session-cache cleanup, and reception UI states need targeted correction.

Finding counts after reconciliation

Priority	Count	Release meaning
P1	11	Resolve and verify before production use with real payments, passes, or sensitive admin access.
P2	13	Resolve before broader operational rollout; one item depends on the account-closure policy decision.
P3	2	Usability and accessibility follow-ups; fix and verify as part of release hardening.
P0	0	No P0 issue was identified in the source review notes.

How findings were consolidated

Duplicate frontend and cross-stack items were merged into a single register, while distinct root causes remained separate when they need different owners or acceptance tests. Source IDs are retained in every finding and in Appendix A. Where the cross-stack note assigned a higher priority to a related risk, the higher priority is retained; separate failure modes keep their own acceptance tests when remediation differs.

2 Scope and evidence

The two supplied reviews traced source code across the DAIH monorepo. They examined customer and staff journeys, shared request/response contracts, API authorization and services, data migrations, CI, and deployment guidance. The findings describe code paths and risks; they are not exploit or user-journey reproductions.

Journey or area	Source-level coverage	Key result
Identity and session	Customer PWA/admin authentication, MFA, refresh, OAuth, shared API client	Token exposure, open redirect, and stale private cache; no runtime session test.
Booking, payment, refund	Customer booking/checkout and API booking/payment/refund services	Price mismatch, payment settlement/retry, webhook handling, and refund atomicity.
Loyalty and database	Coin ledger, Prisma migrations, customer wallet/admin finance	Legacy loyalty tables dropped without a backfill; no database snapshot was inspected.
QR and reception	Pass generation/retrieval, scanner/check-in, manual lookup	Unsigned-token/role-scope risk, check-in race, stale search state, keyboard access.
Admin operations	Staff, payment records, campaign workflows, deployment path	Demo staff fallback, payment scope, canned AI copy, and migration-runbook mismatch.

Journey or area	Source-level coverage	Key result
Public marketing site	Route and journey inventory for apps/web	No browser, visual, link, or responsive testing.
Shared services	API client/types, CI, outbox, retention, service worker	Cache, event-claim, retention, and missing frontend E2E-gate findings.

Evidence labels

- Static trace: the reviewer followed source, configuration, schema, or documentation paths. Confidence refers to the code behavior observed, not runtime proof.
- High confidence: direct code/configuration path was present in the notes. Conditional impact is stated where it depends on live data, deployment configuration, a sibling origin, or provider behavior.
- Medium confidence: the repository review did not settle external operational policy or runtime behavior; confirm the item with the relevant owner.

No runtime claims: No browser journey, accessibility scan, camera/scanner test, API integration test, migration run, Paystack sandbox flow, or staging check was completed.

3 Recommended release actions

Close the release blockers by evidence, not by code change alone. Each item should end with an owner, a passing acceptance result, and a link to the isolated test evidence.

Gate	Work to close	Evidence required
1. Money and bookings	Correct quantity pricing; reconcile final payment state, amount and currency; make initialization/refund retries idempotent; fix webhook acknowledgement.	Automated tests with provider mocks and an isolated database. Include retries, concurrency, pending/failed results, amount/currency mismatch, and injected failures.
2. Security and authorization	Sanitize policy HTML; narrow CORS; remove OAuth tokens from URLs and validate destinations; secure QR signing and retrieval; enforce payment-role scope.	Negative tests for unsafe HTML/origins/destinations/tokens and role/resource matrix tests. Confirm auth callbacks are not cached.
3. Data preservation	Stop the destructive loyalty drop until a backfill and reconciliation are proven.	Migration rehearsal on a disposable snapshot with nonzero wallet balances and transaction history; signed reconciliation before legacy-table removal.
4. Operational integrity	Make check-in atomic; clear private cache on session end; protect future bookings from retention; claim outbox work; remove misleading staff/search fallbacks.	Concurrency and failure-state tests; verify one active visit, one event side effect, no stale/private data, and accurate empty/error UI.
5. Broader release readiness	Resolve cancellation/account-closure policy, correct deployment instructions, campaign labeling, keyboard and contrast issues, and add frontend browser tests.	Documented product/policy decision; CI browser journeys; keyboard-only review; contrast check; runbook rehearsal.

Suggested sequencing

- Block production release and freeze the loyalty table-drop migration.
- Close P1 payment, security, QR, permissions, and data-preservation issues; run isolated acceptance tests.
- Close operational P2 items and agree the supported customer account-closure process.
- Add browser and accessibility coverage, then repeat smoke tests against the exact candidate build and migration set.
- Make a new release decision from test evidence and the candidate commit; the static review alone is not a release sign-off.

4 Test execution and environment limits

The source notes report the following exact checks. A clean worktree is not evidence that the application passes its quality gates.

Check	Reported result	Meaning
git status --short	No output; worktree clean	Read-only review left no repository changes.
git rev-parse --short HEAD	ced762d in the cross-stack note	Reported baseline for that note; frontend-only snapshot linkage was not stated.
node --version	v18.18.2	Below the repository minimum of Node $\geq 20.9.0$ and the CI Node 20 expectation.
pnpm --version	Failed: Corepack EPERM while creating its cache	Pinned package-manager environment was unavailable; install/build/test commands were not run.
docker compose ps	Docker CLI unavailable	No local PostgreSQL/Redis services were started.
Lint, typecheck, build, unit/integration, migration	Not run	No test-pass claim is made.
Browser, accessibility, camera, scanner, Paystack, staging	Not run	No visual, device, provider, or deployed-environment claim is made.

What is needed for verification

- A disposable workspace with Node 20.9 or newer, pinned pnpm, installed dependencies, and isolated PostgreSQL/Redis.
- Browser automation for all four frontends, including session expiry, multi-unit booking, payment return, QR scanning and offline/update behavior.
- A mocked or sandbox payment setup for pending, failed, mismatched amount/currency, retries, refunds, webhook replay, and injected database errors.
- A disposable database snapshot populated with representative legacy loyalty data for a before/after migration reconciliation.
- Keyboard-only and contrast review, plus controlled camera permission/device tests for reception.

5 Source-level controls already observed

The review notes also identify controls worth preserving. These were observed in code and were not runtime-tested.

- Login and registration validate requests; verified-email checks and portal-role boundaries exist. Staff login is gated by MFA.
- Refresh uses an HttpOnly cookie, single-flight refresh in the shared client, and server-side token rotation/revocation.
- Booking ownership and state checks exist, capacity holds use a resource-row lock, and payment initialization reads the stored booking amount.
- Webhook signatures use HMAC with timing-safe comparison; event IDs are used for idempotency.
- Refund initiation and approval are separated between Operations and Finance/Super Admin, with self-approval prohibited.
- The access service checks booking state/time windows and scanner operations have a role allowlist; QR retrieval does not apply an equally narrow scope.
- Camera-denial UI offers hardware-scanner/manual alternatives; the service worker precaches an offline shell and bypasses API/identity endpoints. OAuth callback caching remains a separate fix and verification item.

6 Consolidated findings

All affected paths below are repository-relative. The source notes used an old workstation root; absolute local paths have been normalized here.

P1 Release blockers (11)

DAIH-QA-01 Stored XSS in legal policy content

P1 | Source IDs: FE-SEC-01; XQA-02

Observation: The admin editor captures HTML, the API stores it without sanitizing, and admin/customer policy renderers insert it as HTML. The customer middleware also permits inline-script behavior. The tag-name regex noted in the review is not a security sanitizer.

Impact: A user who can edit a policy could place executable markup in content later opened by customers or staff. Browser execution was not reproduced.

Evidence paths: apps/admin-portal/components/legal/VisualWysiwygEditor.tsx:174; apps/api/src/modules/legal/legal.service.ts:211; apps/customer-pwa/components/legal/RichPolicyRenderer.tsx:22; apps/admin-portal/components/legal/RichPolicyRenderer.tsx:22; apps/customer-pwa/middleware.ts:35

Recommended action: Apply a strict HTML allowlist before storage and again at render boundaries. Remove inline-script CSP allowances where possible and keep approved policy formatting explicit.

Acceptance: Event-handler, SVG, script, and unsafe-URL payloads are rejected or inert in both portals; security tests cover stored content and all policy renderers.

Evidence confidence: High for the unsanitized source path; runtime execution not tested.

DAIH-QA-02 Credentialed CORS trusts every HTTPS daih.ng subdomain

P1 | Source IDs: API-SEC-02; XQA-03

Observation: The API accepts a broad HTTPS subdomain pattern and enables credentialed CORS. The shared client sends credentials with API requests.

Impact: A compromised or untrusted matching sibling origin could make credentialed API requests and read allowed responses. The existence of an attacker-controlled sibling was not checked.

Evidence paths: apps/api/src/app.ts:42,58; packages/api-client/src/client.ts:233

Recommended action: Replace the wildcard pattern with an exact, environment-specific allowlist. Review cookie domain and SameSite settings with the approved app origins.

Acceptance: An unlisted subdomain receives no credentialed CORS permission; each approved web, customer, reception, and admin origin is verified in an isolated test.

Evidence confidence: High for the configured origin rule; exploitability depends on an untrusted matching origin.

DAIH-QA-03 OAuth fallback exposes an access token in the callback URL

P1 | Source IDs: FE-AUTH-03; XQA-01 (token exposure)

Observation: The API places an access token in an OAuth redirect query parameter and the customer callback reads it from the URL. The service worker does not exclude the callback and caches successful navigation requests using their full URL.

Impact: A short-lived bearer token can reach browser history, URL logging, referrer surfaces, or Cache Storage. Cache persistence and browser exposure were not tested.

Evidence paths: apps/api/src/modules/identity/identity.service.ts:351; apps/api/src/modules/identity/identity.controller.ts:275,278; apps/customer-pwa/app/auth/callback/page.tsx:14; apps/customer-pwa/public/service-worker.js:63

Recommended action: Remove access tokens from URLs. Use an authorization code exchanged once or establish the HttpOnly session directly; return no-store responses and exclude all identity callbacks from service-worker caching.

Acceptance: OAuth callback URLs, history, referrers, and Cache Storage contain no access token while callback sign-in still establishes the intended session.

Evidence confidence: High for token-in-URL code path; actual cache behavior not browser-tested.

DAIH-QA-04 QR token authenticity and retrieval scope are too weak

P1 | Source IDs: API-ACCESS-04; API-RBAC-08 (QR scope); XQA-07

Observation: The verifier accepts unsigned legacy daih_qr_ tokens and QR signing can fall back to a committed development key. The QR retrieval controller also allows every non-customer role to fetch another customer's pass.

Impact: A forged or weakly signed pass for a known active booking may be accepted, and finance or management users may retrieve bearer QR data outside their intended role. Physical access impact depends on booking knowledge and scanner behavior.

Evidence paths: apps/api/src/modules/access/qr-token.util.ts:15,83; apps/api/src/config/env.ts:168; apps/api/src/modules/access/access.routes.ts:42; apps/api/src/modules/access/access.controller.ts:25; apps/api/src/modules/access/access.service.ts:446

Recommended action: Remove unsigned legacy acceptance; require a strong QR_SIGNING_SECRET at production startup; authorize pass retrieval only for the booking owner and explicitly allowed scanner roles with booking scope.

Acceptance: Unsigned, malformed, fallback-signed, expired, and replayed tokens fail. Finance/management/customer roles cannot fetch another user's QR; approved scanner roles and owners can access only permitted bookings.

Evidence confidence: High for code behavior; physical scanner and deployed environment were not tested.

DAIH-QA-05 Booking quantity is displayed but not priced by the API

P1 | Source IDs: BOOK-PRICE-05; XQA-04

Observation: The PWA computes selectedPlan.price multiplied by quantity, but the hold request, shared DTO, and API schema contain no quantity. The service stores one plan price as totalAmount and discounts use the same one-unit base.

Impact: A multi-hour or multi-unit booking can be quoted at one amount and charged or invoiced at another, undermining customer trust and revenue accuracy.

Evidence paths: apps/customer-pwa/app/(dashboard)/book/[resourceId]/page.tsx:784,937; packages/types/src/booking.types.ts:55; apps/api/src/modules/booking/booking.schema.ts:40; apps/api/src/modules/booking/booking.service.ts:520

Recommended action: Calculate the authoritative charge server-side from validated time span, quantity, and pricing rules. Return a quote breakdown and use that same calculation for discounts, payment, and invoice.

Acceptance: Multi-hour, daily, and monthly cases have matching UI quote, hold, discount, payment, and invoice totals; client-supplied prices cannot change the amount.

Evidence confidence: High for the UI/API mismatch; no payment journey was executed.

DAIH-QA-06 Loyalty migration drops legacy balances and history

P1 | Source IDs: DB-LOYALTY-06; XQA-09

Observation: A migration creates new coin tables and a later migration drops loyalty_wallets and loyalty_transactions without copying balances or ledger rows.

Impact: If a target database has legacy loyalty data, deployment can remove balances and transaction history. Database contents and migration effects were not inspected or run.

Evidence paths: apps/api/src/db/prisma/migrations/20260921194000_add_peedee_coin_and_refunds/migration.sql:13-14; apps/api/src/db/prisma/migrations/20260923200000_drop_legacy_loyalty_tables/migration.sql:10,14

Recommended action: Pause the destructive drop. Build and rehearse a backfill, reconcile per-user balances and aggregate value, retain a recovery window, and require sign-off before dropping legacy tables.

Acceptance: A disposable snapshot with nonzero wallets and history migrates with exact per-user and aggregate reconciliation before and after the migration.

Evidence confidence: High for the destructive migration sequence; existence of live legacy rows is unknown.

DAIH-QA-07 Payment settlement and customer status can disagree

P1 | Source IDs: XQA-05 (settlement and UI status)

Observation: The booking page shows payment success for any resolved verification response, including PENDING or FAILED. The webhook path can mark a transaction successful from the event name without reconciling provider amount and currency against the local transaction.

Impact: Customers may see a false confirmation, bookings may be confirmed against a mismatched payment, or paid sessions may remain unresolved. Provider behavior was not exercised.

Evidence paths: apps/customer-pwa/app/(dashboard)/bookings/page.tsx:317;
apps/api/src/modules/payments/payments.service.ts:347,657

Recommended action: Make state transitions depend on verified final provider status and exact local amount/currency/reference matching. Present pending, failed, and confirmed states separately in the PWA.

Acceptance: Mocked PENDING, FAILED, wrong-amount, and wrong-currency responses never show success or confirm a booking; only a reconciled successful transaction confirms exactly once.

Evidence confidence: High for the code paths; sandbox/provider tests not run.

DAIH-QA-08 Payment retries can create multiple pending transactions

P1 | Source IDs: XQA-06

Observation: Initialization stops only when verification of the latest pending transaction reports success. A still-pending or failed verification falls through to create another provider checkout; the local pending row is committed before the provider call, and concurrent requests can pass the pre-check together.

Impact: Retries can leave multiple active pending records and may create duplicate provider sessions or charges. Duplicate charges were not tested.

Evidence paths: apps/api/src/modules/payments/payments.service.ts:190,237

Recommended action: Use a booking-scoped idempotency key and atomic payment-attempt claim. Reuse or reconcile the existing reference after timeouts instead of creating another attempt.

Acceptance: Pending, timeout, verification error, and concurrent requests preserve one active payment attempt per booking and safely reconcile the provider reference.

Evidence confidence: High for duplicate local pending records; medium for duplicate provider sessions or charges.

DAIH-QA-09 Operations access bypasses payment record ownership checks

P1 | Source IDs: API-RBAC-08 (payment scope); XQA-08

Observation: Payment detail, verification, and invoice routes have no role middleware. The controller treats OPERATIONS_ADMIN as staff and omits owner scoping, despite the shared role table not granting PAYMENTS_READ.

Impact: Operations users may read or verify other customers' transactions and invoices beyond the declared permission boundary.

Evidence paths: packages/types/src/roles.types.ts:46; apps/api/src/modules/payments/payments.routes.ts:91;
apps/api/src/modules/payments/payments.controller.ts:98,108

Recommended action: Apply explicit payment permissions and resource ownership at the route and service boundaries. Keep Finance/Super Admin permissions documented and least-privileged.

Acceptance: Role-matrix tests deny Operations access to another customer's payment, verification, and invoice; permitted Finance/Super Admin access follows policy and customer access stays owner-scoped.

Evidence confidence: High for the authorization path; role tests were not run.

DAIH-QA-10 Refund provider call occurs before an atomic approval claim

P1 | Source IDs: XQA-10

Observation: Refund approval reads a pending request, checks eligibility, calls the payment provider, and only afterward opens the local transaction to mark the request processed and reverse coins.

Impact: Concurrent approvals may issue more than one provider call. A local database failure after provider success can leave an ambiguous pending request and an unsafe retry path.

Evidence paths: apps/api/src/modules/payments/refund.service.ts:383,438

Recommended action: Atomically claim the refund before external work, use a stable provider idempotency key, and persist the provider result so retries reconcile rather than submit again.

Acceptance: Concurrent approvals create at most one provider refund; injected local failures reconcile using the existing provider refund ID before any repeat call.

Evidence confidence: High for ordering and race window; provider idempotency behavior not tested.

DAIH-QA-11 Webhook processing errors are acknowledged as successful delivery

P1 | Source IDs: API-PAY-09; XQA-05 (error acknowledgement)

Observation: The webhook controller catches processing exceptions and returns HTTP 200. The payment provider can therefore treat a transiently unprocessed event as delivered and omit its retry.

Impact: A temporary database or service failure may leave a payment pending and its booking unconfirmed without a durable recovery path.

Evidence paths: apps/api/src/modules/payments/payments.controller.ts:47,53

Recommended action: Persist a durable webhook event before acknowledging, or return a retryable failure for transient processing errors. Keep event handling idempotent.

Acceptance: An injected processing failure is durably queued or produces a provider retry; replay confirms the booking once and does not duplicate side effects.

Evidence confidence: High for the acknowledgement path; no fault-injection test was run.

P2 Important before broader operational rollout (13)

DAIH-QA-12 OAuth callback destination is not restricted to in-app paths

P2 | Source IDs: API-AUTH-07; XQA-01 (destination)

Observation: OAuth initiation accepts a destination, places it in signed state, and the customer callback passes it to router.replace without an effective same-origin check.

Impact: A crafted sign-in link may send a user to an external destination after authentication. Deployed browser behavior was not confirmed.

Evidence paths: apps/api/src/modules/identity/identity.controller.ts:186;
apps/customer-pwa/app/auth/callback/page.tsx:15

Recommended action: Validate and normalize the destination server-side and again in the callback. Default to a fixed in-app route for invalid values.

Acceptance: Absolute, protocol-relative, script-scheme, malformed, and off-origin destinations resolve to the safe default; valid app-relative destinations continue to work.

Evidence confidence: High for unchecked destination flow; browser redirect behavior not reproduced.

DAIH-QA-13 Concurrent check-ins can create duplicate visit sessions

P2 | Source IDs: API-ACCESS-10; XQA-12

Observation: The access service checks current check-in state before a transaction, then unconditionally updates the booking and creates a visit session within the transaction. Two terminals can both pass the stale pre-check.

Impact: Duplicate active visit sessions can corrupt occupancy and customer visit history. Concurrency behavior was not reproduced.

Evidence paths: apps/api/src/modules/access/access.service.ts:798,828;
apps/api/src/db/prisma/schema.prisma:571

Recommended action: Make check-in a conditional state transition under a row lock or compare-and-set, and add a database invariant against multiple open sessions per booking.

Acceptance: Two concurrent attempts yield one success, one ALREADY_CHECKED_IN response, and one open visit session.

Evidence confidence: High for race window; runtime concurrency not tested.

DAIH-QA-14 Session expiry clears identity but leaves private browser cache

P2 | Source IDs: FE-PRIV-12; XQA-13

Observation: The shared client persists booking, payment-history, and wallet responses in localStorage under unscoped keys. Explicit logout clears the cache, but the session-expiry callback clears identity state without invalidating it.

Impact: Sensitive personal data may remain on a shared or revoked device and could be displayed before a new authenticated session.

Evidence paths: packages/api-client/src/cache.ts:25; packages/api-client/src/auth-provider.tsx:110-111;
packages/api-client/src/client.ts:486,865

Recommended action: Avoid persistent storage for private responses or partition it by user and purge local and in-memory cache on every expiry, revocation, and refresh rejection.

Acceptance: After expiry or refresh rejection, profile data and all private cache entries are removed before navigation or rendering for another user.

Evidence confidence: High for cleanup mismatch; browser storage behavior not tested.

DAIH-QA-15 Confirmed bookings offer a cancellation action the API rejects

P2 | Source IDs: XQA-11

Observation: The customer booking page offers Cancel for confirmed bookings and promises slot release, while the API rejects customer cancellation of confirmed bookings under the no-refund policy.

Impact: Customers are invited into a predictable failure and are not shown the applicable refund or rescheduling route.

Evidence paths: apps/customer-pwa/app/(dashboard)/bookings/page.tsx:903;
apps/api/src/modules/booking/booking.service.ts:782

Recommended action: Align the visible action and explanation with the actual policy. Keep cancellation available for held or pending bookings where the API permits it.

Acceptance: Confirmed bookings show the correct policy and next step; held/pending bookings still cancel and release holds successfully.

Evidence confidence: High for UI/API policy mismatch; no user journey was run.

DAIH-QA-16 No customer account closure route or settings flow was identified

P2 | Source IDs: XQA-14

Observation: The reviewed settings flow exposes logout and the identity routes include avatar deletion, but no customer deactivation/deletion route or matching settings action was found. The policy text describes a right to request erasure.

Impact: This is a product/privacy workflow gap if self-service closure is required. A support-managed process may exist outside the reviewed repository.

Evidence paths: apps/customer-pwa/app/(dashboard)/settings/page.tsx:370; apps/api/src/modules/identity/identity.routes.ts:192; policy wording noted in review

Recommended action: Confirm and document the supported closure process or implement one. Define how sessions, future bookings, payment records, and legal retention obligations are handled.

Acceptance: The supported process is documented and tested for confirmation, session revocation, future obligations, and retention outcomes.

Evidence confidence: Medium; absence was established from the reviewed repository paths, not external support procedures.

DAIH-QA-17 Retention can anonymize a customer with a future booking

P2 | Source IDs: API-RET-15; XQA-15

Observation: The dormant-customer predicate excludes recent sessions and recently created bookings, but does not exclude an old-created booking whose service time is in the future or whose state remains active. The anonymizer then replaces identifying fields.

Impact: A long-lead future booking may lose the customer details needed to fulfill it. Whether a matching record exists is unknown.

Evidence paths: apps/api/src/jobs/retention.worker.ts:90,98,128,130

Recommended action: Exclude customers with future or nonterminal bookings, unresolved payment/refund activity, and other retained obligations before anonymization.

Acceptance: A dormant customer with a future confirmed booking is not anonymized until the booking and related obligations are resolved.

Evidence confidence: High for the missing predicate; actual matching data not inspected.

DAIH-QA-18 Multiple outbox workers can dispatch the same event

P2 | Source IDs: API-EVENT-11; XQA-16

Observation: Workers select pending outbox rows, run handlers, and then mark them published without an atomic cross-process claim or lease. An in-process polling flag does not coordinate replicas.

Impact: Multiple replicas may send duplicate notifications or repeat other event side effects.

Evidence paths: apps/api/src/modules/events/outbox.service.ts:50,75

Recommended action: Claim rows atomically with a processing state or row locking such as SKIP LOCKED; make consumers idempotent as a second line of defence.

Acceptance: Two isolated worker instances processing the same batch cause each event side effect once and recover safely after worker failure.

Evidence confidence: High if multiple workers run; deployment topology and runtime effects were not checked.

DAIH-QA-19 Manual reception search can leave stale results selectable

P2 | Source IDs: RECEIPT-UX-14; XQA-17

Observation: A failed manual lookup logs a warning but does not clear prior results. After a successful search, a failed later search can leave a previous customer's result visible and clickable.

Impact: Staff may accidentally continue a check-in using a match from the prior query.

Evidence paths: apps/reception-app/app/page.tsx:352-353,720

Recommended action: Clear or hide results when a new search starts, show a visible and announced error, and disable stale selections.

Acceptance: After a success followed by a network failure, no old match remains selectable and the failure is announced.

Evidence confidence: High for state path; browser reproduction not run.

DAIH-QA-20 Admin staff screen can show demo users after empty or failed API results

P2 | Source IDs: ADMIN-OPS-13; XQA-18

Observation: The staff page initializes from DEFAULT_DEMO_STAFF and replaces it only when the API returns a nonempty list. Empty, unauthorized, or failed responses can leave sample identities and counts displayed as real records.

Impact: Operations users may act on fabricated staff names or metrics and misunderstand system state.

Evidence paths: apps/admin-portal/app/staff/page.tsx:16,80

Recommended action: Start with explicit loading, empty, and error states. Keep demo content behind an unmistakable development-only flag.

Acceptance: Empty, 401, and 500 responses never display demo identities or counts in production mode.

Evidence confidence: High for fallback logic; API response behavior not tested.

DAIH-QA-21 Reception manual-search results lack keyboard semantics

P2 | Source IDs: A11Y-19; XQA-19

Observation: Manual result cards are clickable div elements without a button role, tab stop, or keyboard handler. Keyboard-only staff may not be able to select a result.

Impact: A core reception task is inaccessible to staff who rely on keyboard input or assistive technology.

Evidence paths: apps/reception-app/app/page.tsx:722

Recommended action: Use native buttons or links with visible focus, accessible names, and state. Announce result counts and errors.

Acceptance: A keyboard-only user can search, reach each result, understand it, and activate it with standard keys.

Evidence confidence: High for missing native semantics; no browser or screen-reader audit was run.

DAIH-QA-22 Production runbook recommends Prisma db push instead of migrations

P2 | Source IDs: DEPLOY-16

Observation: The manual production guide directs operators to prisma db push, while CI uses prisma migrate deploy. The two paths do not preserve the same migration review and history discipline.

Impact: Production schema changes may bypass checked-in migrations, making change review, recovery, and environment consistency harder.

Evidence paths: docs/HOSTINGER_VPS_DEPLOYMENT_GUIDE.md:243; .github/workflows/ci.yml:70

Recommended action: Align the production runbook with the migration-based deployment process and document backup, health-check, and recovery gates.

Acceptance: The documented production path applies only reviewed checked-in migrations and has a rehearsed recovery procedure.

Evidence confidence: High for the documentation mismatch; no deployment was run.

DAIH-QA-23 Campaign AI copy endpoint returns canned text and a fixed confidence

P2 | Source IDs: CAMPAIGN-17

Observation: The service switches by campaign type and returns hard-coded copy; tone is read but not used and the confidence value is constant. The UI labels the workflow AI copy generation.

Impact: Users may believe copy is generated from their inputs and treat a fabricated confidence score as meaningful.

Evidence paths: apps/api/src/modules/campaigns/campaign.service.ts:943; campaign UI workflow noted in review

Recommended action: Integrate the approved generator or relabel this as a template picker and remove the confidence claim.

Acceptance: If presented as AI generation, changing prompt and tone changes the output and confidence is computed with a defined method or omitted.

Evidence confidence: High for service behavior; no campaign generation run was performed.

DAIH-QA-24 CI has no browser end-to-end gate for the four frontends

P2 | Source IDs: QA-18

Observation: The reviewed app manifests expose build/typecheck/lint but no frontend journey tests; CI test execution is API-focused and no Playwright/Cypress setup was found.

Impact: Authentication, booking amount, payment return, QR scanning, role screens, offline behavior, and responsive journeys can regress without a browser gate.

Evidence paths: Four app manifests; .github/workflows/ci.yml; API Vitest setup referenced by review (exact manifest line numbers not recorded)

Recommended action: Add isolated browser journeys using disposable services and controlled provider mocks. Keep the tests independent of shared or production systems.

Acceptance: CI covers registration/session expiry, multi-unit quote/payment, QR/scanner errors, admin role access, and offline/update behavior.

Evidence confidence: High for the reviewed manifest/CI inventory; no CI job was executed.

P3 Usability and accessibility follow-up (2)

DAIH-QA-25 Availability API failure is presented as available

P3 | Source IDs: FE-BOOK-20; XQA-20

Observation: On availability API failure, the booking UI sets availability to true and displays remaining capacity. The server rechecks during hold creation, so this is primarily misleading UX rather than a confirmed overbooking path.

Impact: Customers may attempt checkout without verified capacity, especially during an outage.

Evidence paths: apps/customer-pwa/app/(dashboard)/book/[resourceId]/page.tsx:739

Recommended action: Represent availability as unknown or error after a failed request and disable checkout until the server confirms capacity.

Acceptance: A network/server failure shows a clear retry state and is never described as available.

Evidence confidence: High for fallback logic; no browser test was run.

DAIH-QA-26 Offline page small text falls below WCAG AA contrast

P3 | Source IDs: A11Y-21

Observation: The review calculated approximately 2.56:1 contrast for 11px slate-400 text on a white card, below the 4.5:1 target for normal-sized text.

Impact: The small copy may be difficult to read for users with low vision or in poor display conditions.

Evidence paths: apps/customer-pwa/app/offline/page.tsx:90

Recommended action: Use a darker text color or adjust the background, then validate the rendered colors with an automated contrast check.

Acceptance: Normal-size offline-page text meets at least 4.5:1 contrast and remains legible in browser visual review.

Evidence confidence: High for the reported color calculation; browser rendering not checked.

Appendix A Source ID reconciliation

This table preserves the identifiers from the two source review notes and maps them to the consolidated register.

Source review	Original ID	Consolidated finding
Frontend review	FE-SEC-01	DAIH-QA-01
Frontend review	API-SEC-02	DAIH-QA-02
Frontend review	FE-AUTH-03	DAIH-QA-03
Frontend review	API-ACCESS-04	DAIH-QA-04
Frontend review	BOOK-PRICE-05	DAIH-QA-05
Frontend review	DB-LOYALTY-06	DAIH-QA-06

Source review	Original ID	Consolidated finding
Frontend review	API-AUTH-07	DAIH-QA-12
Frontend review	API-RBAC-08	DAIH-QA-04, 09
Frontend review	API-PAY-09	DAIH-QA-11
Frontend review	API-ACCESS-10	DAIH-QA-13
Frontend review	API-EVENT-11	DAIH-QA-18
Frontend review	FE-PRIV-12	DAIH-QA-14
Frontend review	ADMIN-OPS-13	DAIH-QA-20
Frontend review	RECEPT-UX-14	DAIH-QA-19
Frontend review	API-RET-15	DAIH-QA-17
Frontend review	DEPLOY-16	DAIH-QA-22
Frontend review	CAMPAIGN-17	DAIH-QA-23
Frontend review	QA-18	DAIH-QA-24
Frontend review	A11Y-19	DAIH-QA-21
Frontend review	FE-BOOK-20	DAIH-QA-25
Frontend review	A11Y-21	DAIH-QA-26
Cross-stack review	XQA-01	DAIH-QA-03, 12
Cross-stack review	XQA-02	DAIH-QA-01
Cross-stack review	XQA-03	DAIH-QA-02
Cross-stack review	XQA-04	DAIH-QA-05
Cross-stack review	XQA-05	DAIH-QA-07, 11
Cross-stack review	XQA-06	DAIH-QA-08
Cross-stack review	XQA-07	DAIH-QA-04
Cross-stack review	XQA-08	DAIH-QA-09
Cross-stack review	XQA-09	DAIH-QA-06
Cross-stack review	XQA-10	DAIH-QA-10
Cross-stack review	XQA-11	DAIH-QA-15
Cross-stack review	XQA-12	DAIH-QA-13
Cross-stack review	XQA-13	DAIH-QA-14
Cross-stack review	XQA-14	DAIH-QA-16
Cross-stack review	XQA-15	DAIH-QA-17
Cross-stack review	XQA-16	DAIH-QA-18
Cross-stack review	XQA-17	DAIH-QA-19
Cross-stack review	XQA-18	DAIH-QA-20
Cross-stack review	XQA-19	DAIH-QA-21
Cross-stack review	XQA-20	DAIH-QA-25

Appendix B Severity and release interpretation

Severity	Count	Interpretation used in this report
P1	11	Release blockers: resolve and verify before production use involving payments, access passes, or sensitive admin data.
P2	13	Operational or product-risk items to close before broader rollout; confirm policy-dependent account closure.
P3	2	Lower-severity usability/accessibility defects; correct and verify during release hardening.
P0	0	No P0 issue identified by the source reviews.

This report consolidates the supplied findings; it is not a new source audit, test execution record, penetration test, privacy opinion, or release authorization.